

# AWS re:Invent

NOV. 28 – DEC. 2, 2022 | LAS VEGAS, NV

STG308-R

# Advanced security patterns on Amazon S3

Bryant Cutler

Principal Engineer, Amazon S3  
AWS

Rafael Koike

Principal Solutions Architect  
AWS



© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.



**Bryant Cutler**

14 years at AWS

SQS, SNS, IAM, IoT, S3



**Rafael Koike**

7 years at AWS

Infrastructure, Security and Storage

# Q&A ANYTIME

but especially at the end



Content warning:

# EXTENDED ANALOGY



**1. People looking out for him**

**2. Safety gear**

**3. An example to follow**



**1. Dedicated security team**

**2. Security tools**

**3. Patterns to follow with S3**

# Your S3 security team



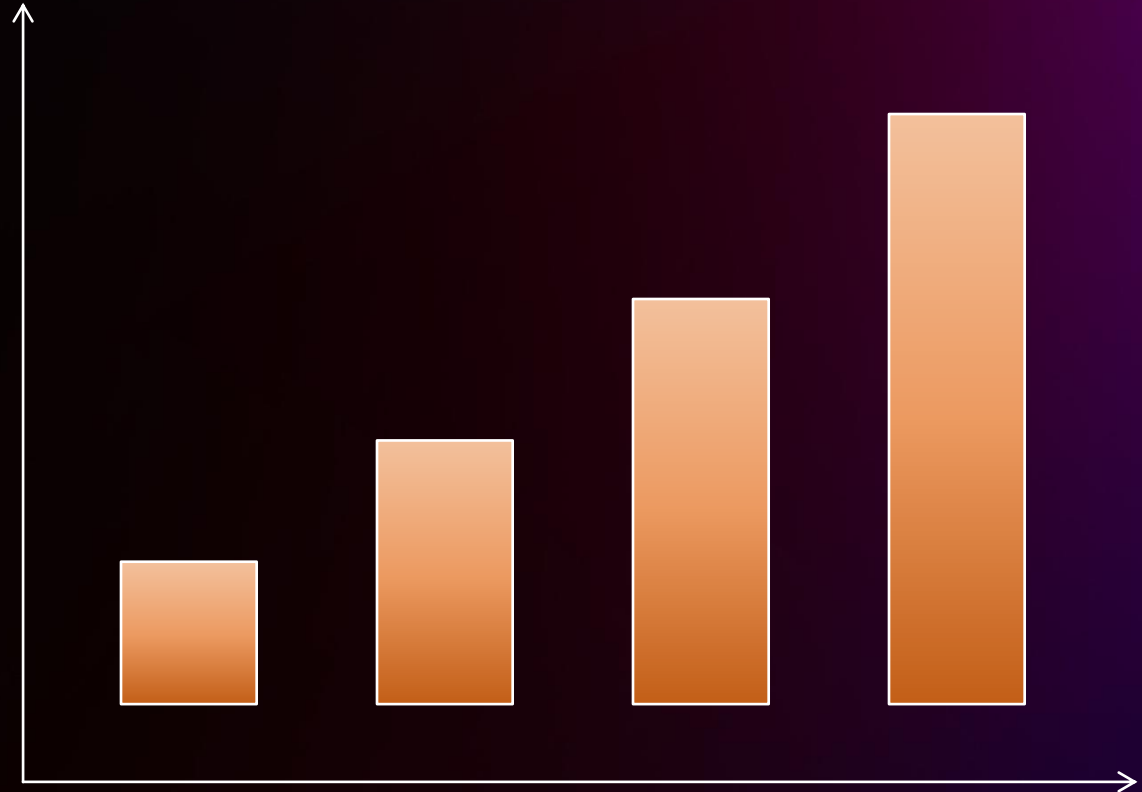
# Continuously “raising the bar”

Performance

Cost-efficiency

Ease of use

Security



Block Public Access (BPA)

SSE-KMS bucket keys

Object Ownership controls (“disable ACLs”)

Expected bucket owner header

Resource account context

TLS 1.0/1.1 deprecation

# Every customer matters

“Shadow mode” validation of changes

Both public notification *and* direct communication of changes

Existing resources' behavior does not change

# AWS Security Tools





# Boundaries

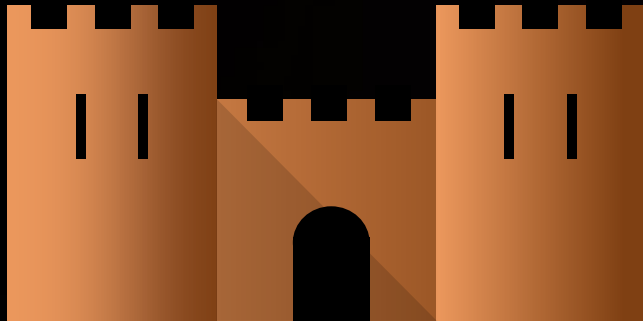


# Bridges



# Audit

# Boundaries



"Broad" mechanisms

Centralized authority

Regulatory and policy compliance

Security invariants

# Example boundaries

|             |              |
|-------------|--------------|
| "me"        | "not me"     |
| "test"      | "production" |
| "raw"       | "processed"  |
| "inside"    | "outside"    |
| "trusted"   | "untrusted"  |
| "project X" | "project Y"  |
| "public"    | "private"    |

# Tools for boundary creation

Separate AWS accounts

AWS Organizations

Service Control Policies (SCPs)

IAM permission boundaries

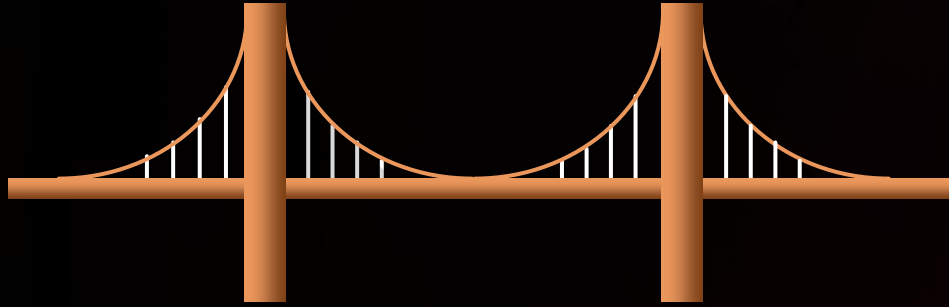
VPCE policies

S3 bucket policy

```
{“Effect” : “Deny”,  
  “Principal”: “*”,  
  “Action”: “*”,  
  “Condition”: {  
    “StringNotEquals”: {  
      “aws:PrincipalOrgId” :  
        “<my org>”  
    }  
  }  
}
```

Example Resource Control Policy (RCP)

# Bridges



“Specific” mechanisms

Distributed authority

Principal of least privilege

Optimize for agility

# Tools for bridge building

**S3 Access Points** can be:

- VPC-specific
- Prefix-specific
- Multi-regional access points
- Object Lambdas

```
{“Effect” : “Allow”,  
  “Principal”: “*”,  
  “Action”: “s3:GetObject*”,  
  “Resource”:  
    “arn:aws:s3:::mybucket/prefix/*”,  
  “Condition”: {  
    “StringLike”: {  
      “s3:DataAccessPointAccount” :  
        “<myaccount>”  
    }  
  }  
}
```

Example bucket policy

# Auditing & review



Proactive config introspection  
Anomalous traffic detection  
Err on the side of comprehensive  
Adjust retention to bound expense

# Tools for audit

Permissions: IAM Access Analyzer 

Traffic: AWS CloudTrail, S3 Access Logs

Data sensitivity: AWS Macie

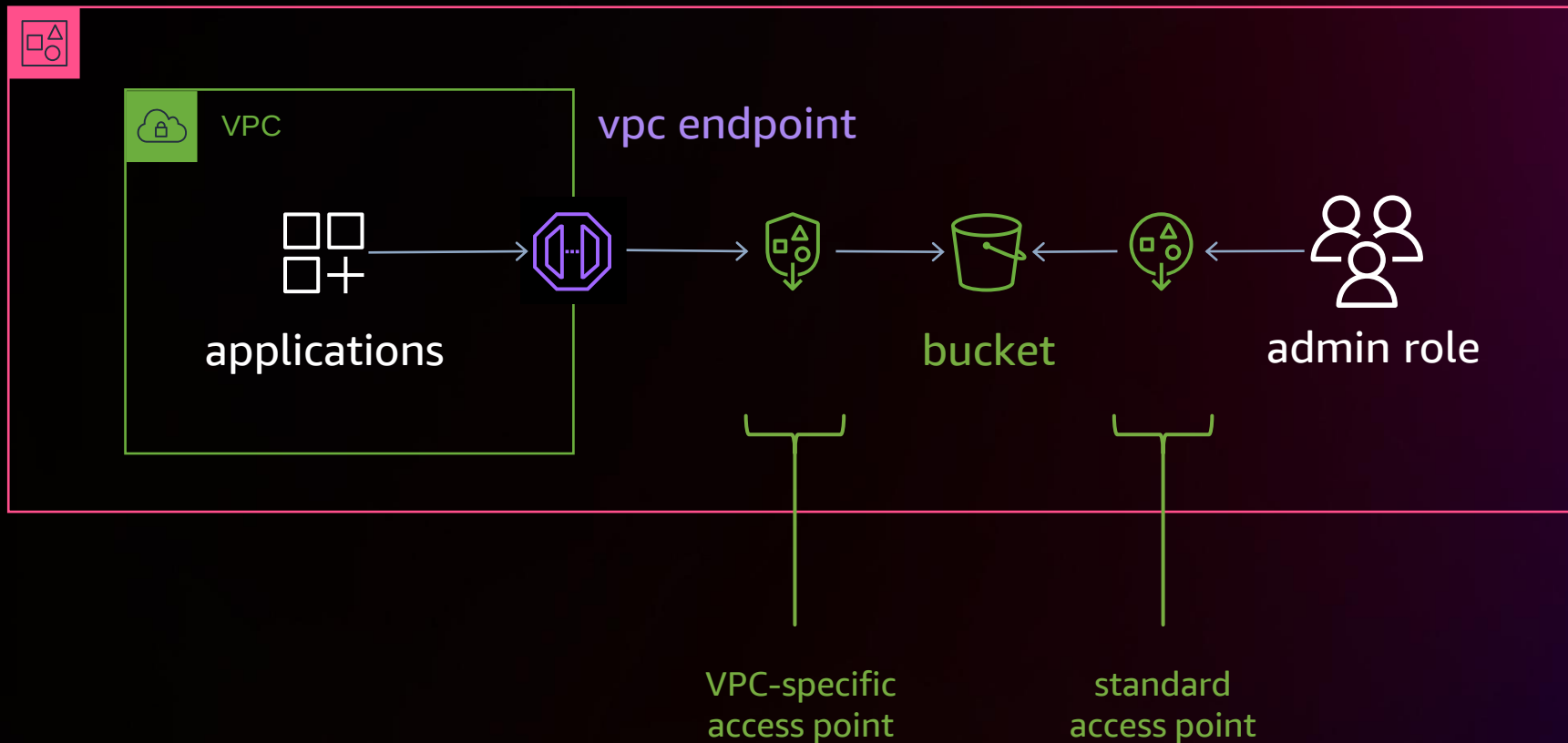
Configuration: AWS Config

Threat detection: Amazon GuardDuty

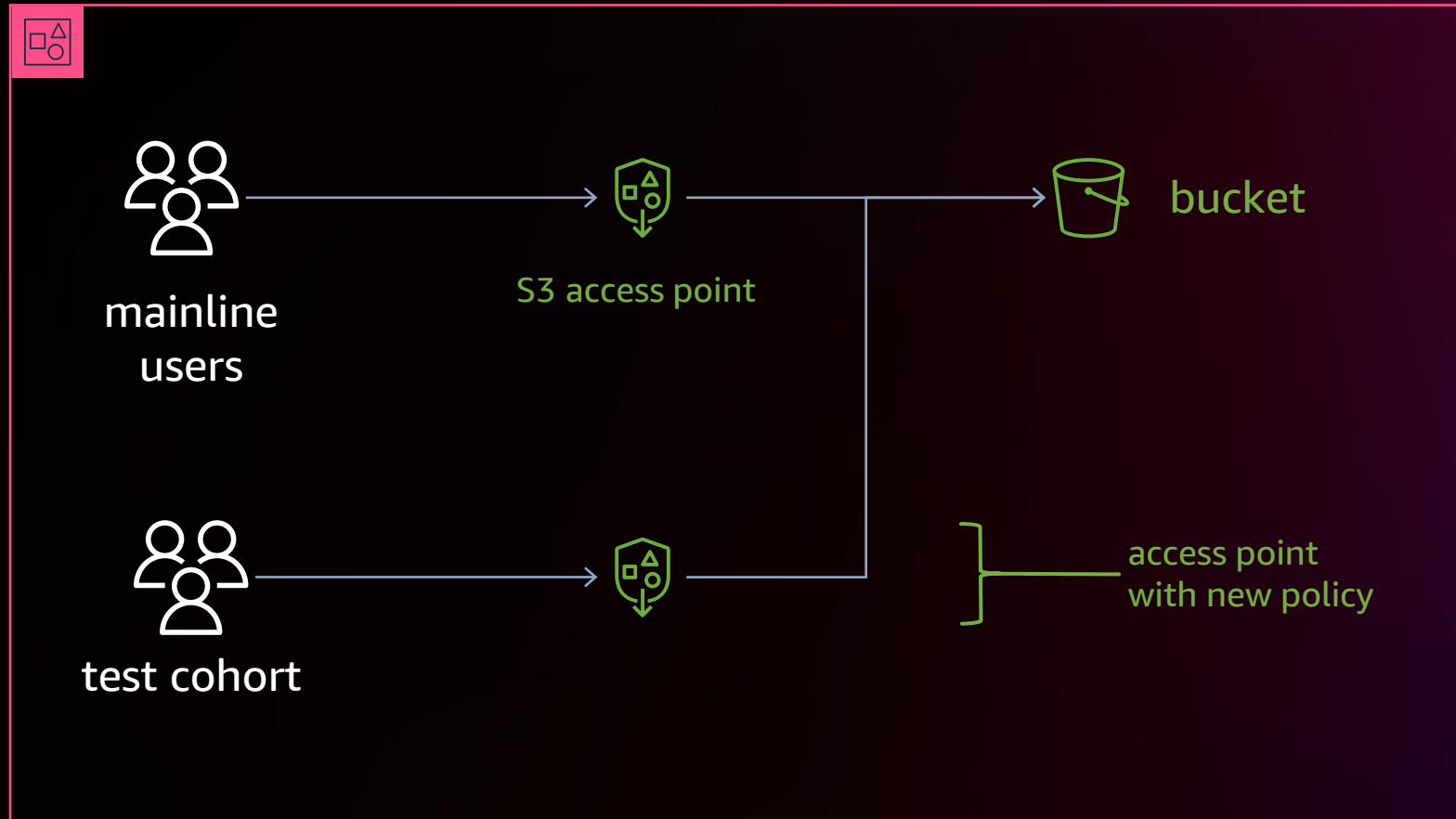
# Patterns



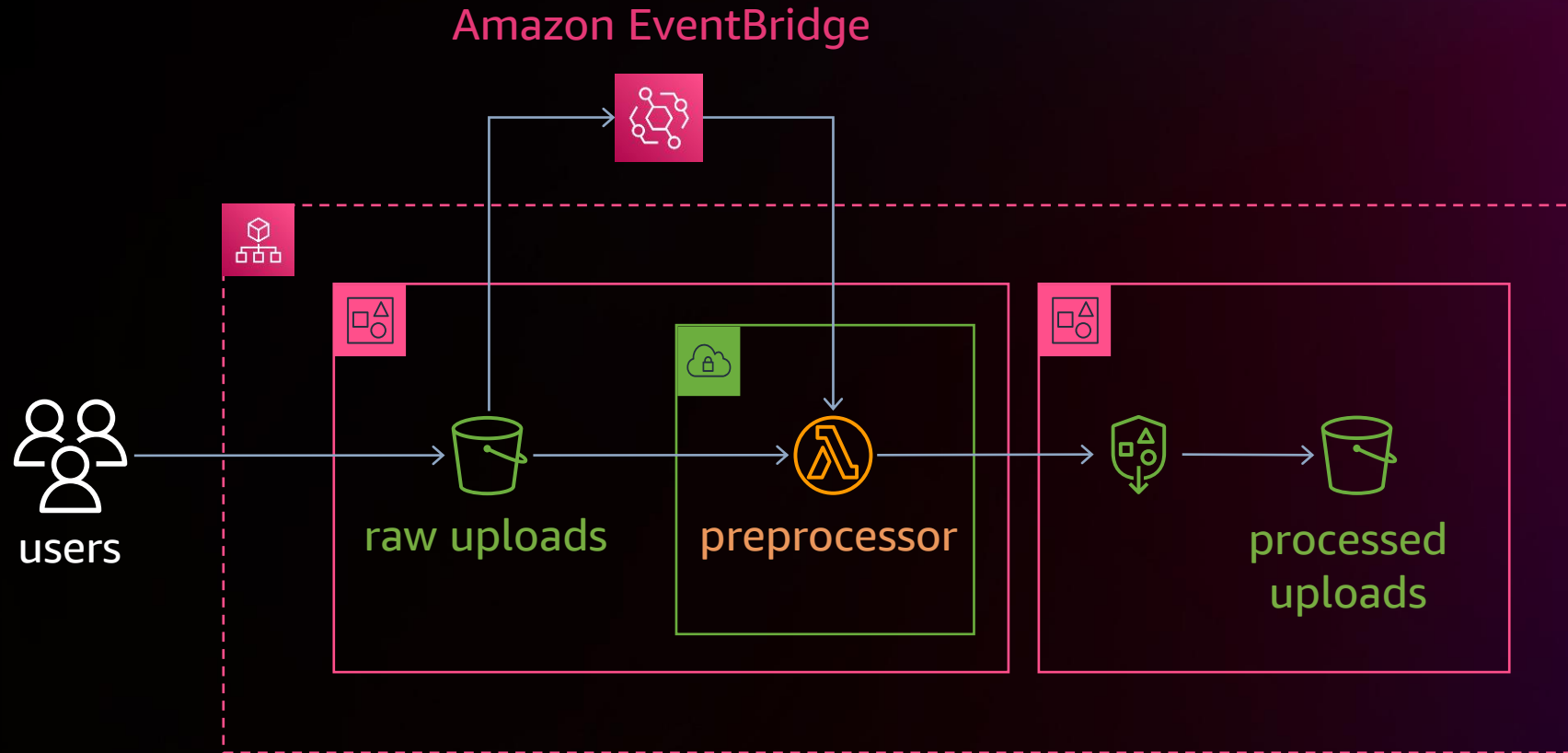
# Don't lock the keys in the car



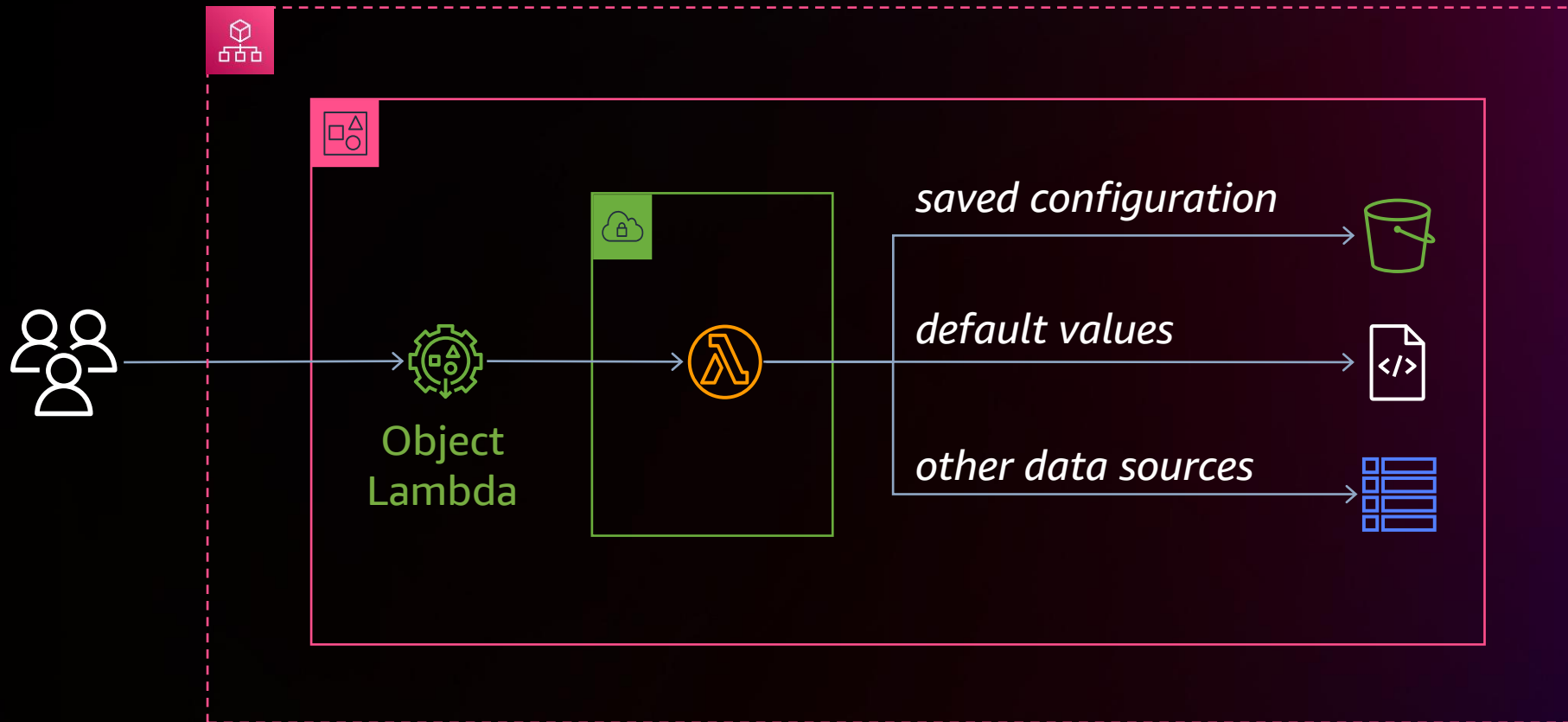
# A/B new policy testing



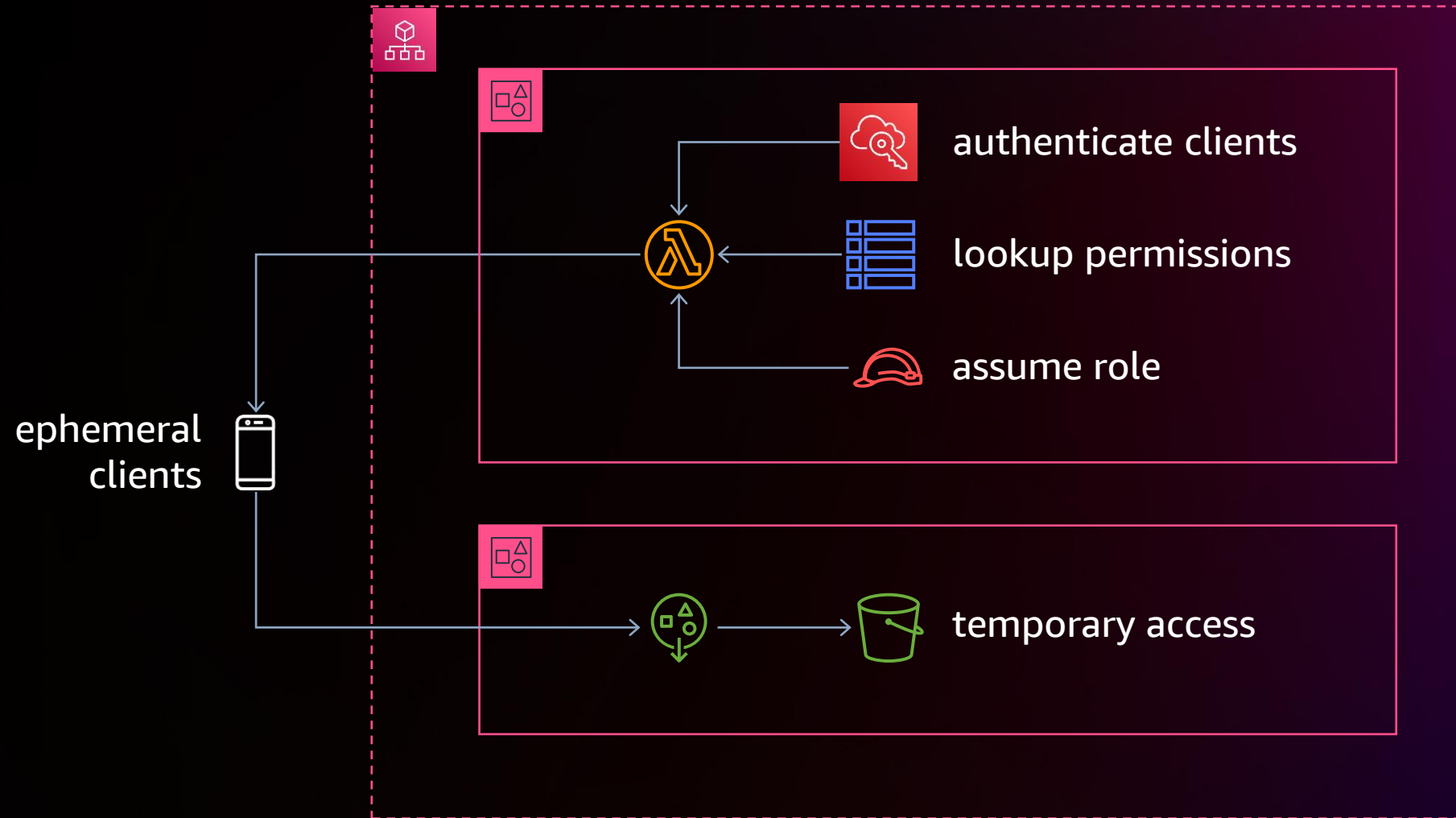
# Serverless DMZ



# Virtual S3 objects



# Token Vending Machine



# Bonus round



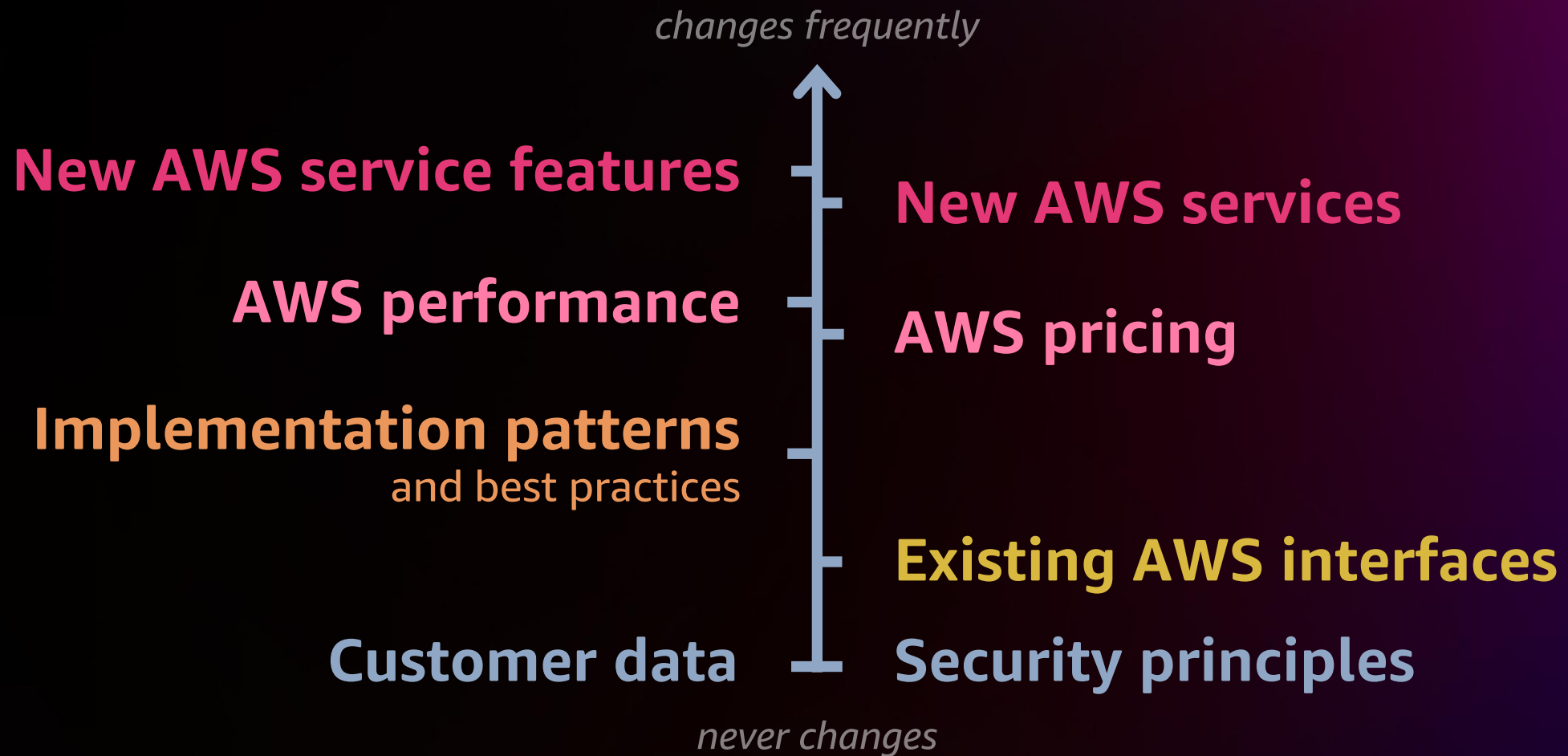
# Namespaced S3 references

*bucketname* → (*bucketname, region, owner*)

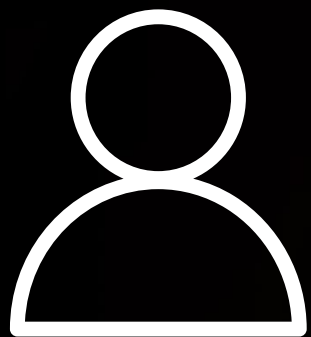
# Progress in security

|                    |   |                                   |
|--------------------|---|-----------------------------------|
| S3 website hosting | ➡ | S3 + CloudFront for static assets |
| CloudFront OAI     | ➡ | CloudFront OAC                    |
| IP-based access    | ➡ | Identity/attribute-based access   |

# Plan for interface updates



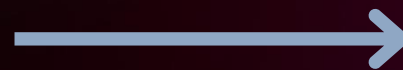
# The **MOST** important AWS pattern



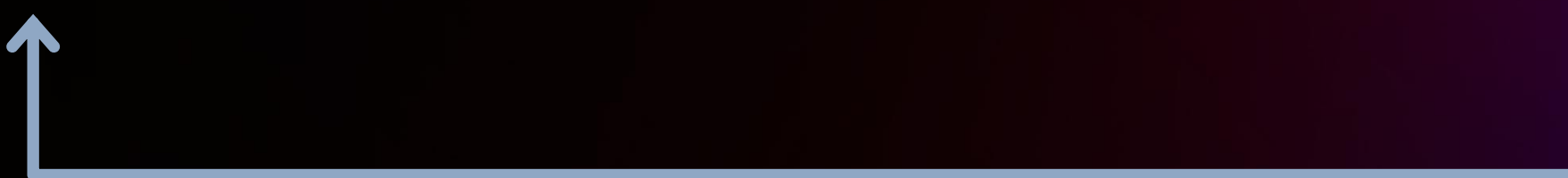
**Customers**



**AWS teams**



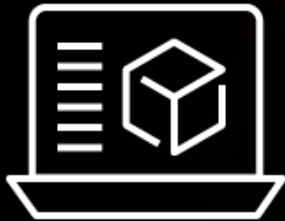
**Better AWS**





# Continue your AWS Storage learning

**Build a  
learning plan**



Set your AWS Storage  
Learning Plans via  
**AWS Skill Builder**

**Increase your  
knowledge**



Use our **Ramp-Up Guides**  
to build your storage  
knowledge

**Earn AWS  
Storage badges**



Demonstrate your  
knowledge by achieving  
**digital badges**

**[aws.training/storage](https://aws.training/storage)**



# Thank you!

Bryant Cutler

bcutler@amazon.com

Rafael Koike

koiker@amazon.com

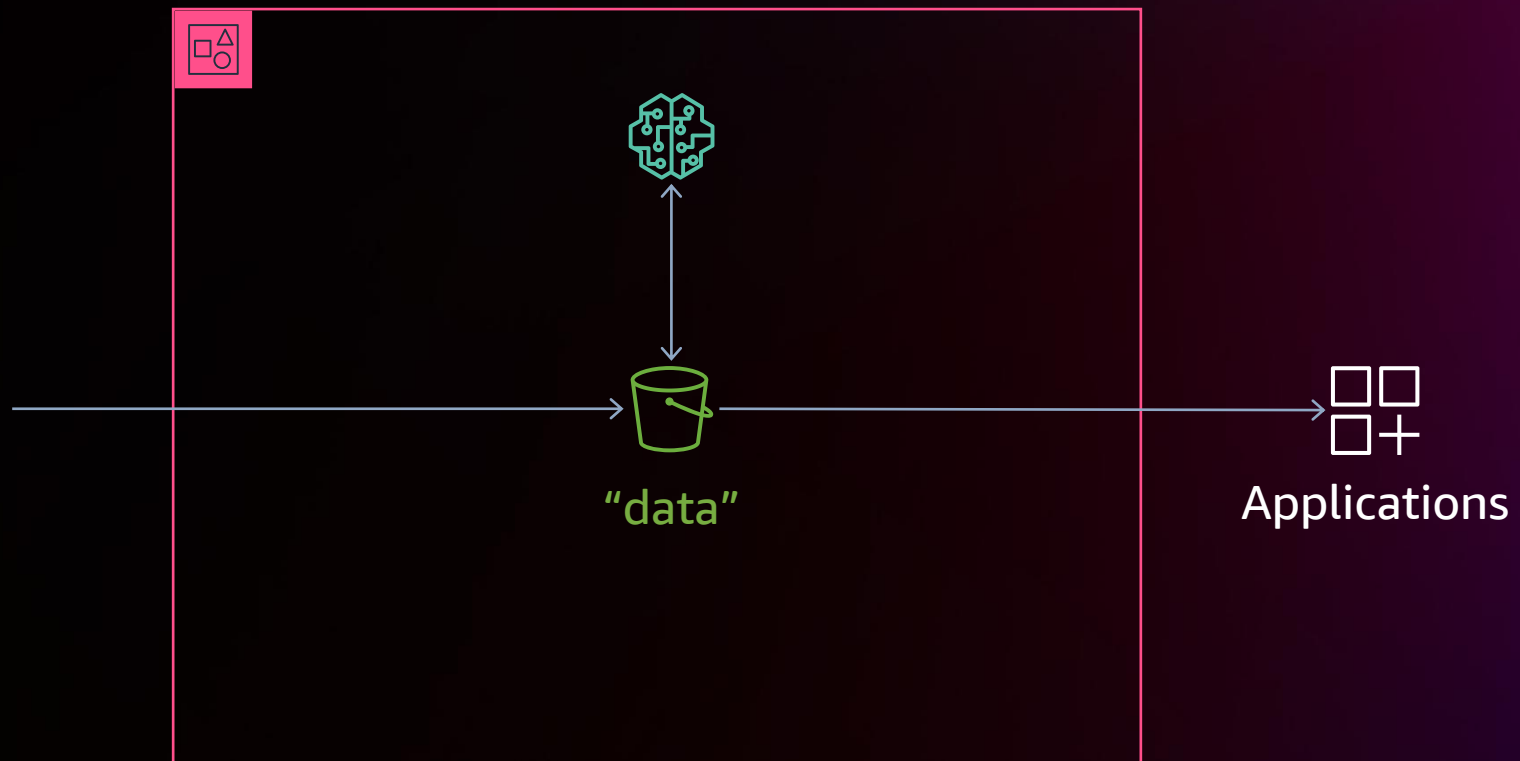


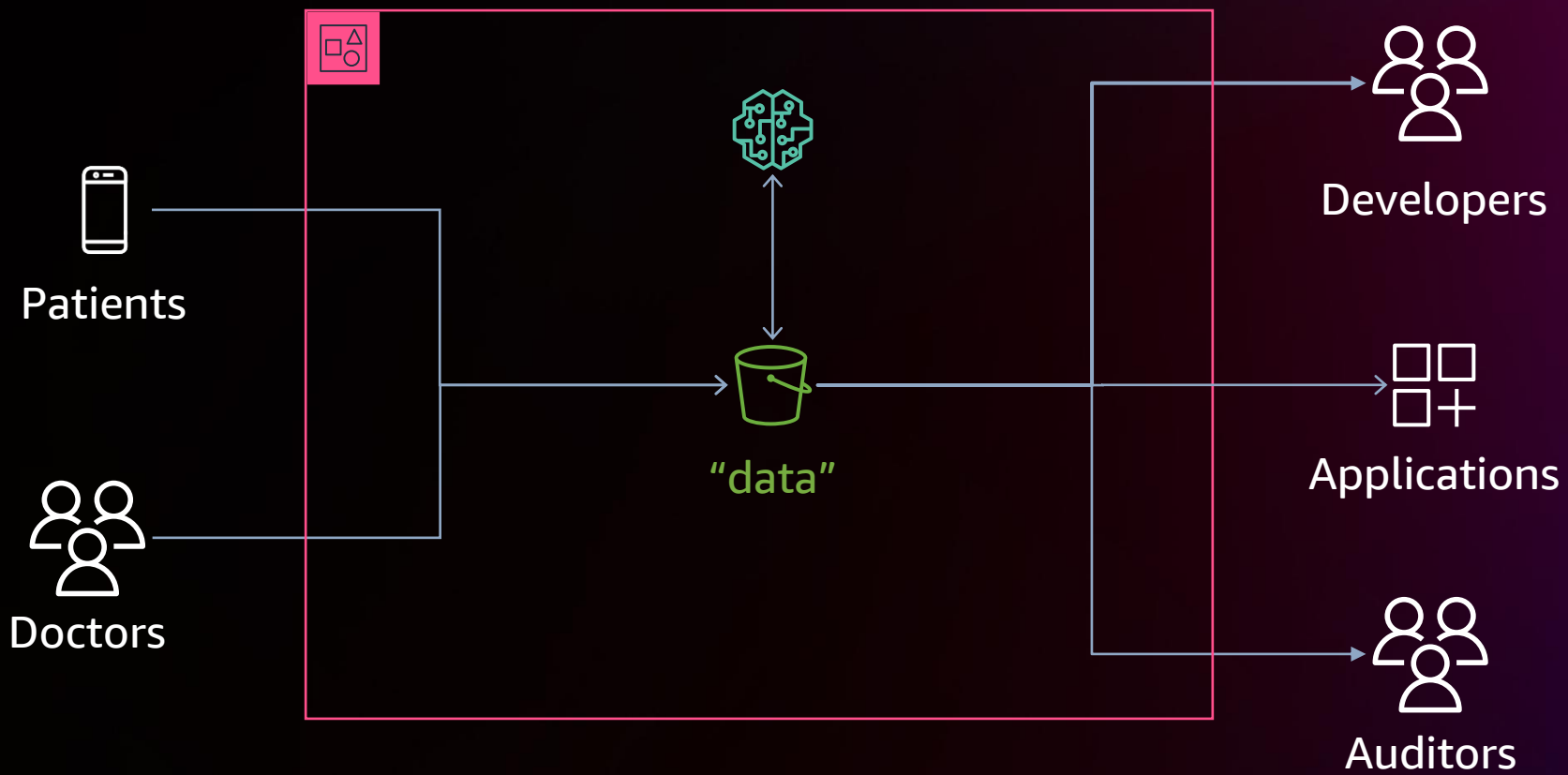
Please complete the session survey in the **mobile app**

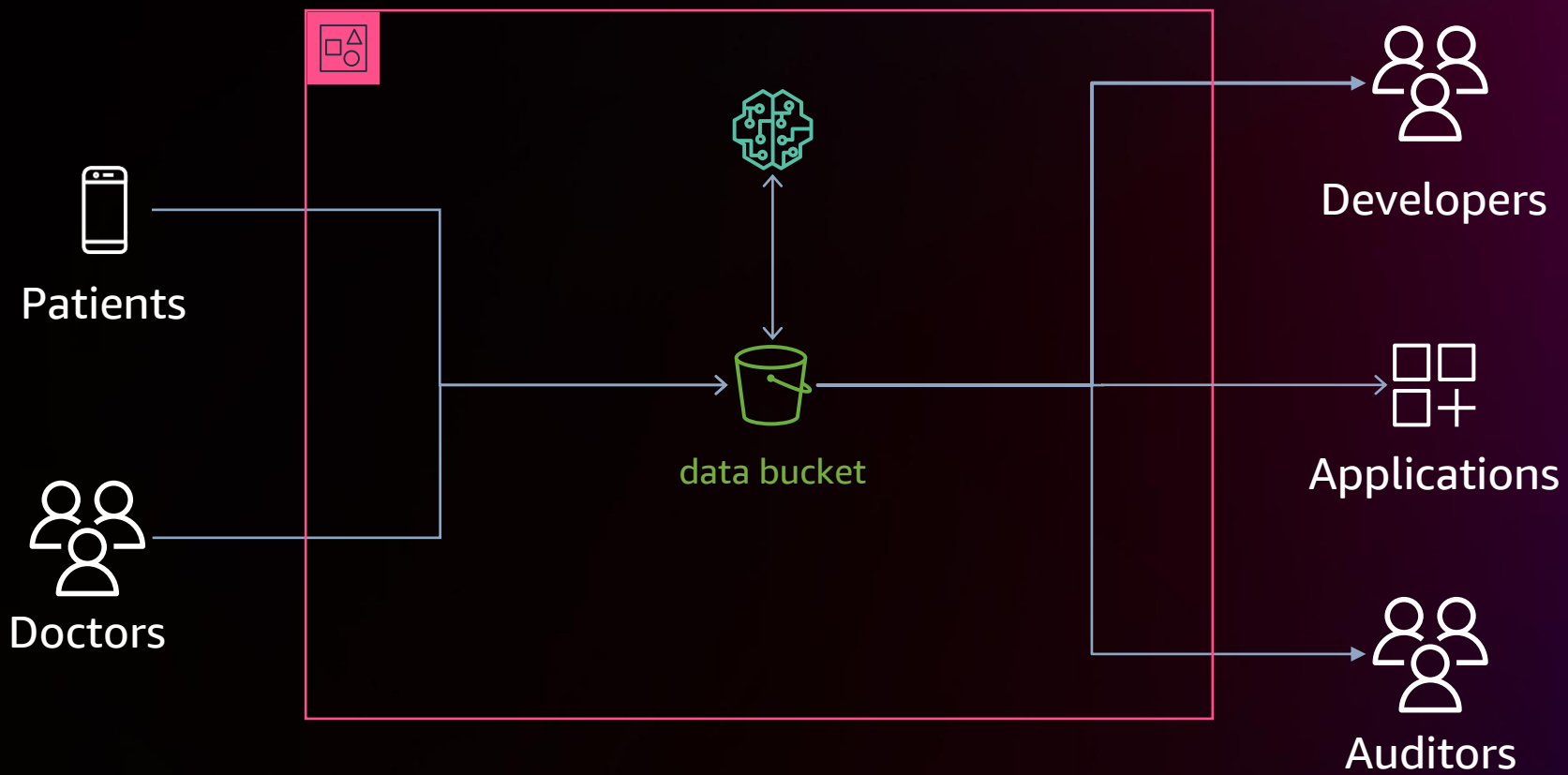


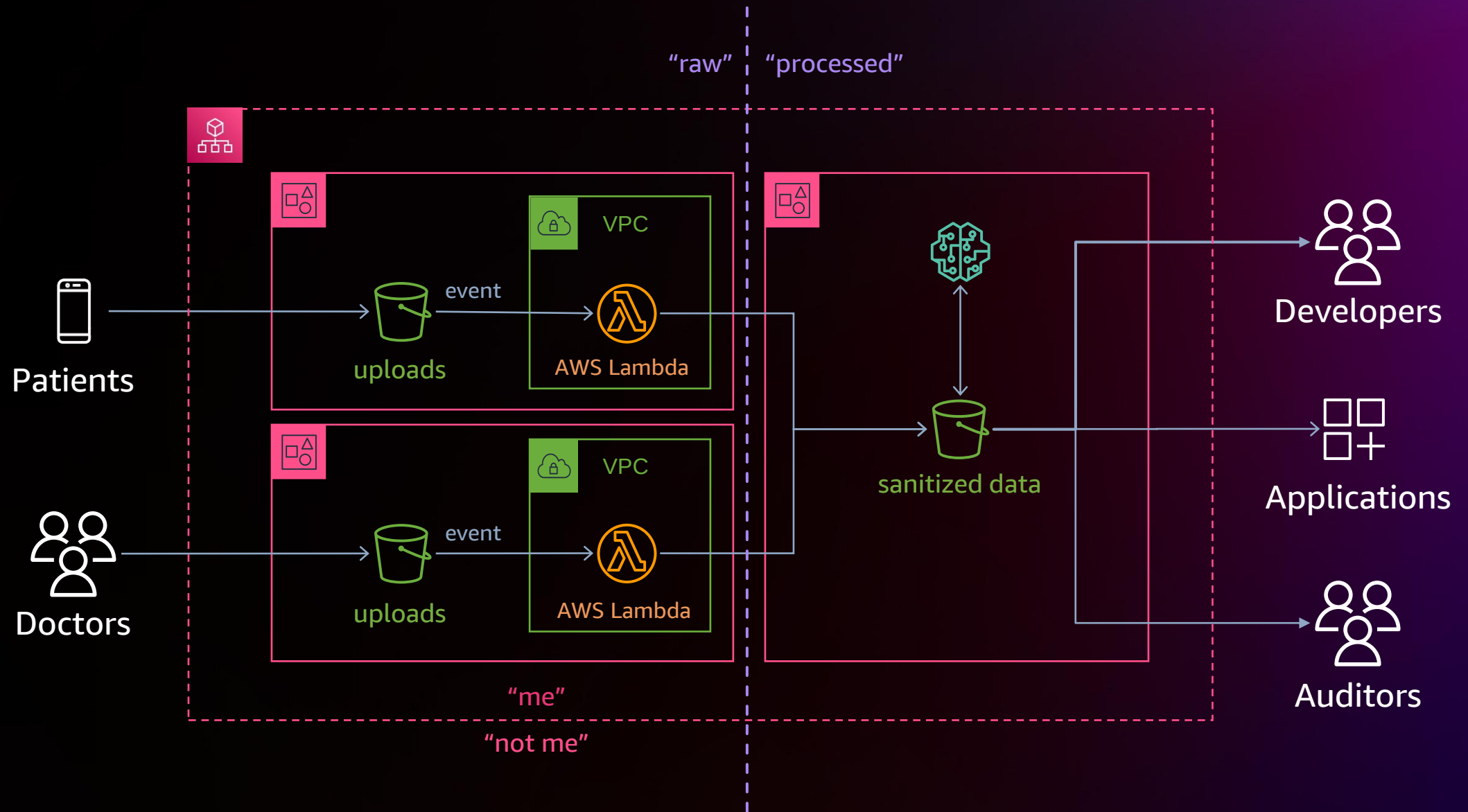
© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

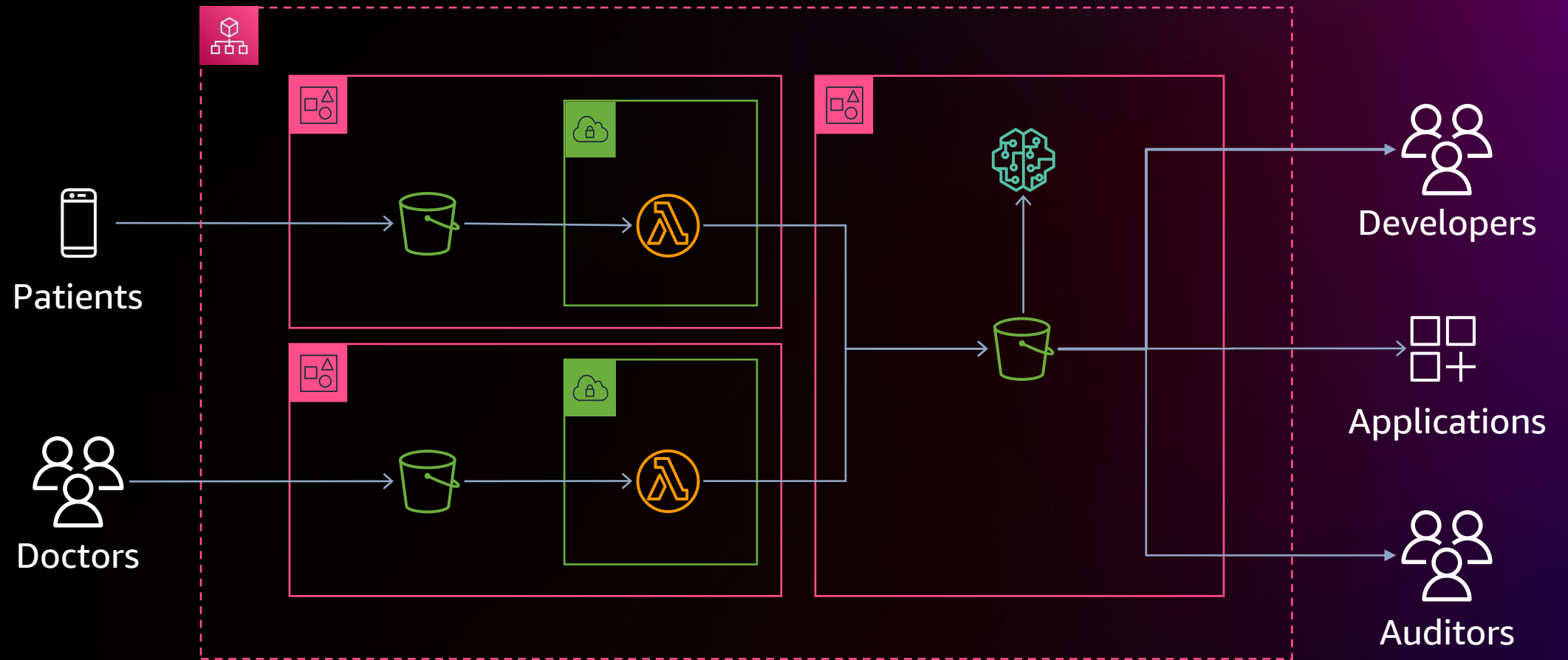




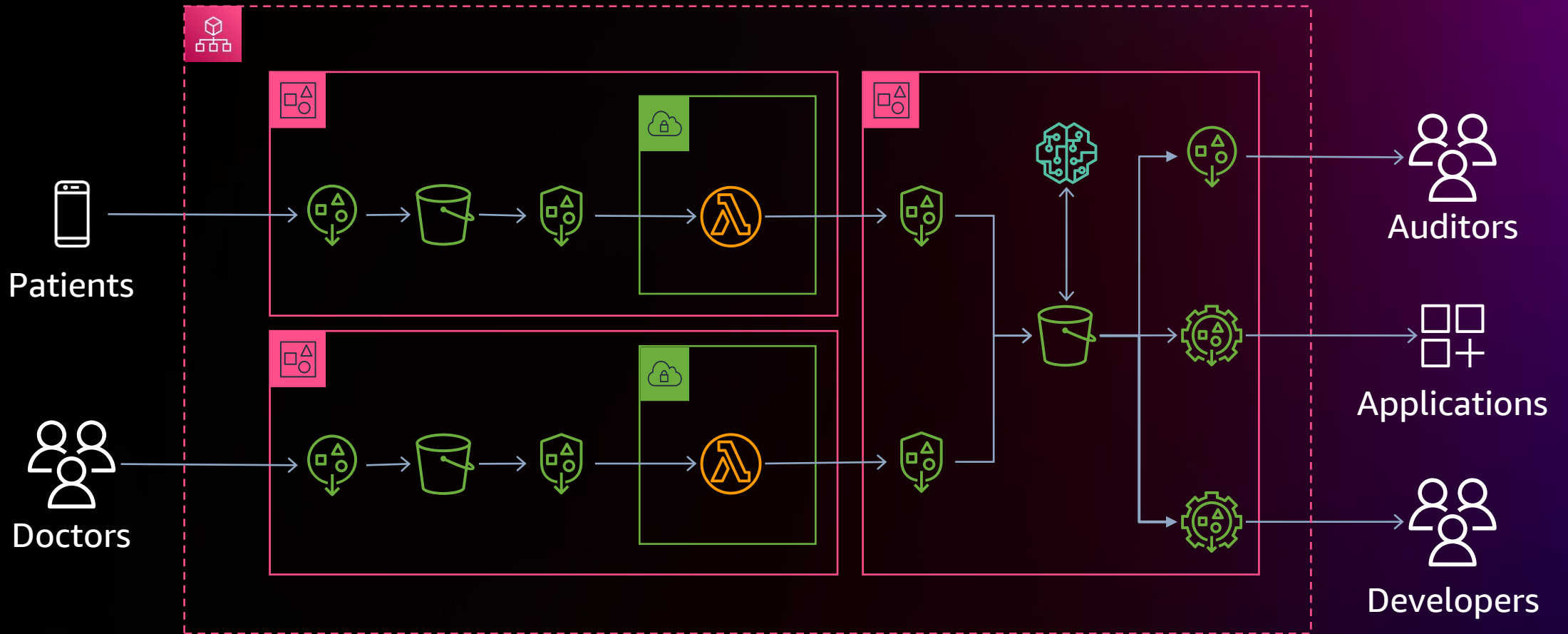


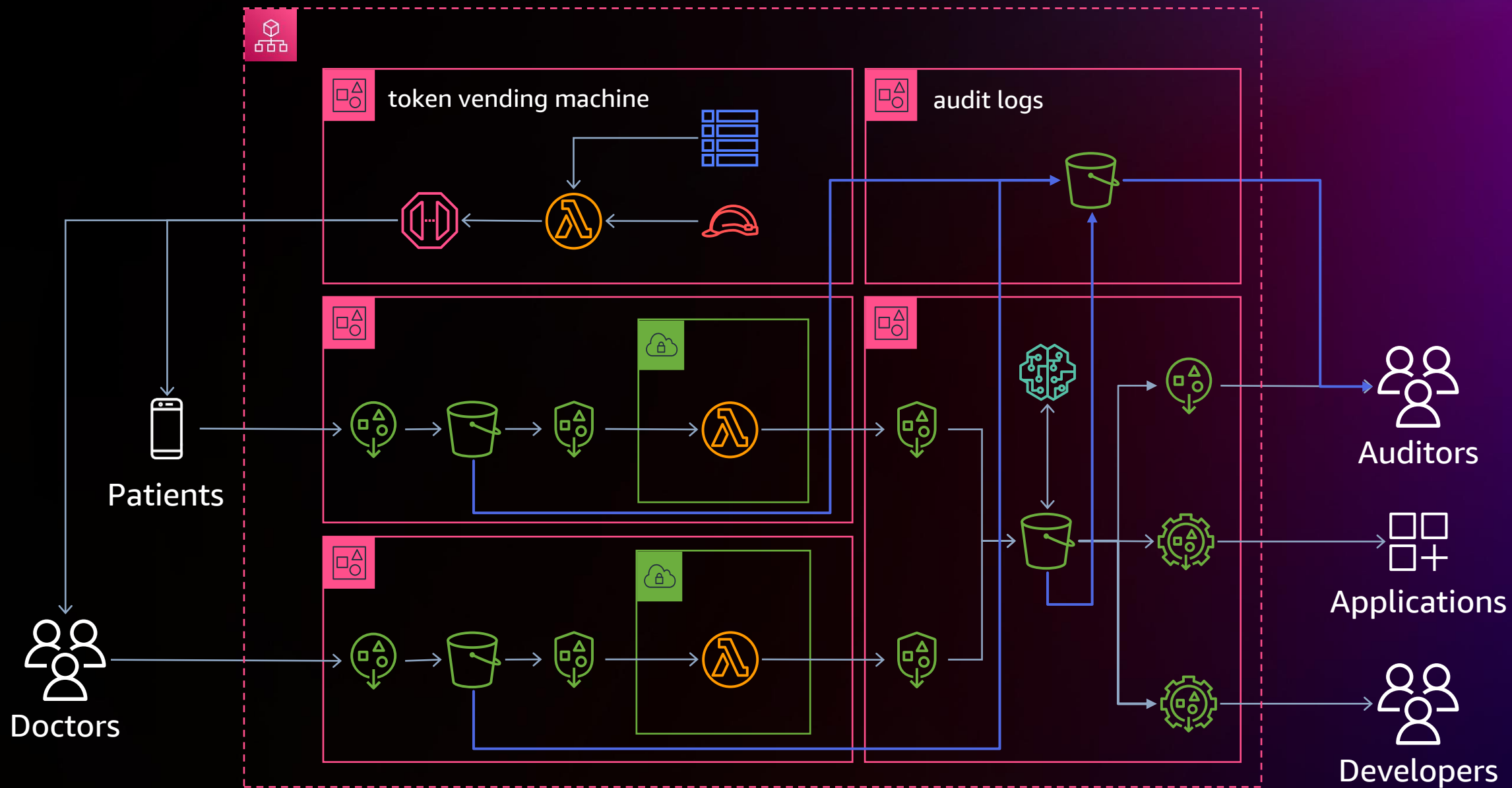


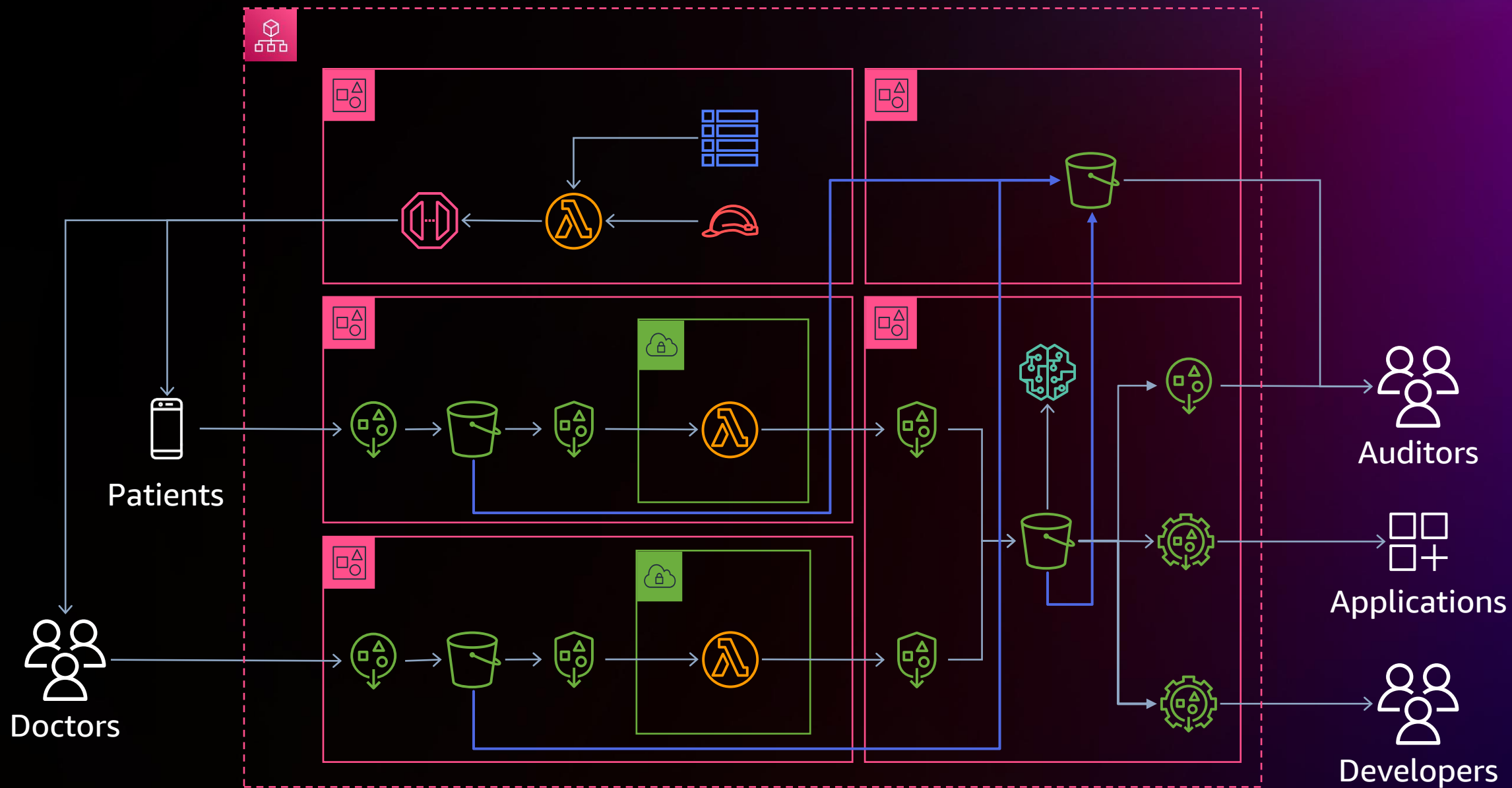












# Thank you!

Bryant Cutler

bcutler@amazon.com

Rafael Koike

koiker@amazon.com



Please complete the session survey in the **mobile app**



© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.